

Phishing Detection & Awareness Report

A Professional Security Analysis & Employee Training Guide

Prepared by:	Security Analysis Team
Date:	April 09, 2026
Classification:	Internal Use – Employee Training
Version:	1.0

Table of Contents

1. Executive Summary
2. What is Phishing?
3. Phishing Email Analysis – Sample 1
4. Phishing Email Analysis – Sample 2
5. Phishing Email Analysis – Sample 3
6. Risk Classification Matrix
7. Common Phishing Indicators
8. How Phishing Attacks Work
9. Prevention Guidelines
10. Do's and Don'ts for Employees
11. Incident Response Steps
12. Conclusion & Recommendations

1. Executive Summary

Phishing remains the most prevalent cyber threat facing organizations worldwide. According to industry reports, over 90% of successful data breaches begin with a phishing email. These attacks exploit human psychology—using urgency, fear, and trust—to trick employees into revealing credentials, clicking malicious links, or downloading malware.

This report analyzes three representative phishing email samples, identifies common attack indicators, classifies risk levels, and provides actionable prevention guidelines. It is designed for use in employee awareness training and internal security programs.

91%

of breaches start
with phishing

\$4.76M

average cost of a
phishing breach

3.4B

phishing emails
sent daily

2. What is Phishing?

Phishing is a type of social engineering attack where cybercriminals send fraudulent messages—typically via email—designed to trick recipients into taking harmful actions. These actions may include:

- Clicking on malicious links that lead to fake login pages
- Downloading infected attachments containing malware or ransomware
- Sharing sensitive information such as passwords, OTPs, or financial data
- Transferring funds to attacker-controlled accounts

Types of Phishing Attacks

Type	Description	Target
Email Phishing	Mass emails impersonating trusted brands	General users
Spear Phishing	Targeted emails using personal information	Specific individuals
Whaling	Attacks targeting senior executives	C-suite / VPs
Smishing	Phishing via SMS text messages	Mobile users
Vishing	Voice-based phishing over phone calls	Anyone with a phone

3. Phishing Email Analysis – Sample 1

Subject: ■■ Urgent: Your Account Will Be Locked

From: security@secure-account-verify[.]com

Body:

Dear User,

We noticed suspicious activity on your account.
To avoid account suspension, please verify your details immediately.

Verify Now: [http://secure-account-verify\[.\]com/login](http://secure-account-verify[.]com/login)

Failure to verify within 24 hours will result in permanent account lock.

Regards,
Security Team

Identified Red Flags

- 1. Fake sender domain:** "secure-account-verify[.]com" is not a legitimate corporate domain. Real companies use their official domain (e.g., support@company.com).
- 2. Urgency and fear tactics:** Phrases like "account will be locked" and "24 hours" create panic to bypass rational thinking.
- 3. Suspicious URL:** The link points to a domain designed to look official but is actually attacker-controlled.
- 4. Generic greeting:** "Dear User" instead of the recipient's actual name indicates a mass phishing campaign.
- 5. No company branding:** Legitimate emails typically include logos, proper formatting, and footer information.

Risk Classification: HIGH RISK – PHISHING

How this attack works: The attacker creates a fake login page that mirrors the real service. When the victim enters credentials, they are captured and sent to the attacker. The victim is then redirected to the real site, often unaware the theft occurred.

4. Phishing Email Analysis – Sample 2

Subject: Invoice #INV-2024-8847 – Payment Overdue

From: billing@quickbooks-invoicing[.]net

Body:

Hello,

Please find attached your overdue invoice #INV-2024-8847.

Amount Due: \$3,249.00

Due Date: Immediate

Please download and review the attached invoice.

[Download Invoice.pdf.exe]

If you have questions, contact our billing department.

Best regards,

Accounting Department

Identified Red Flags

- 1. Spoofed brand domain:** "quickbooks-invoicing[.]net" mimics QuickBooks but is not their real domain (quickbooks.intuit.com).
- 2. Malicious attachment:** The file "Invoice.pdf.exe" uses a double extension to disguise an executable as a PDF document.
- 3. Financial pressure:** "Payment Overdue" and "Immediate" create urgency around money, a powerful motivator.
- 4. Vague sender identity:** "Accounting Department" with no specific contact person or phone number.
- 5. No account details:** Legitimate invoices reference customer IDs, account numbers, or order details.

Risk Classification: CRITICAL RISK – MALWARE DELIVERY

How this attack works: Opening the .exe file installs malware (potentially ransomware or a keylogger) on the victim's device. The malware may encrypt files for ransom, steal stored credentials, or provide persistent backdoor access to the attacker.

5. Phishing Email Analysis – Sample 3

Subject: Re: Q4 Budget Review – Updated Spreadsheet

From: j.thompson@company-internal[.]org

Body:

Hi team,

As discussed in this morning's meeting, here is the updated Q4 budget spreadsheet with the revised figures.

Please review and provide feedback by EOD Friday.

Link: [https://docs-share\[.\]company-internal\[.\]org/budget-q4](https://docs-share[.]company-internal[.]org/budget-q4)

Thanks,
John Thompson
Finance Director

Identified Red Flags

- 1. Impersonation of internal colleague:** Uses a real-sounding name and title to build trust. The domain closely mimics a corporate format.
- 2. Context-aware lure:** References a "meeting" and specific business activity (Q4 budget), making it seem like a legitimate follow-up.
- 3. Lookalike domain:** "company-internal[.]org" appears corporate but is attacker-registered.
- 4. External link to credential harvesting:** The link leads to a fake document portal requiring login, capturing corporate credentials.
- 5. Subtle sophistication:** Unlike obvious spam, this email uses proper grammar, professional tone, and contextual relevance—hallmarks of spear phishing.

Risk Classification: HIGH RISK – SPEAR PHISHING

How this attack works: This is a targeted spear phishing attack. The attacker has researched the organization and crafted a believable email. Clicking the link leads to a fake Microsoft 365 or Google Workspace login page. Captured credentials give the attacker access to email, files, and potentially the entire corporate network.

6. Risk Classification Matrix

Risk Level	Indicators	Recommended Action
LOW (Safe)	Known sender, expected content, verified links, proper branding	Normal processing
MEDIUM (Suspicious)	Unexpected email, minor inconsistencies, unfamiliar sender	Verify with sender via separate channel; do not click links
HIGH (Phishing)	Fake domain, urgency tactics, suspicious links, generic greeting	Do not interact; report to IT security immediately
CRITICAL (Malware)	Executable attachments, embedded macros, drive-by download links	Isolate device; contact security team; do not open attachments

7. Common Phishing Indicators

- **Sender Address Mismatch**

Display name says "Microsoft Support" but email is from random-user@gmail.com or a lookalike domain.

- **Urgency & Threats**

"Act now," "account suspended," "immediate action required"—designed to prevent careful thinking.

- **Suspicious Links**

Hover over links to check the actual URL. Look for misspellings, extra subdomains, or unfamiliar domains.

- **Unexpected Attachments**

Be wary of .exe, .zip, .js, .docm files. Even PDFs can contain malicious scripts.

- **Generic Greetings**

"Dear Customer" or "Dear User" instead of your actual name suggests a mass campaign.

- **Grammar & Spelling Errors**

While sophisticated attacks have improved, many phishing emails still contain noticeable errors.

- **Requests for Sensitive Data**

Legitimate organizations never ask for passwords, OTPs, or full credit card numbers via email.

- **Mismatched Branding**

Incorrect logos, wrong colors, or outdated branding compared to the real company's current design.

8. How Phishing Attacks Work

Understanding the attack lifecycle helps employees recognize and interrupt phishing at any stage:

Step 1: Reconnaissance

The attacker researches the target organization—employee names, roles, email formats, and current projects—using LinkedIn, company websites, and social media.

Step 2: Crafting the Lure

A convincing email is created using spoofed sender addresses, cloned branding, and contextually relevant content designed to trigger an emotional response.

Step 3: Delivery

The phishing email is sent to targeted recipients, often timed during busy periods (Monday mornings, end of quarter) when vigilance is lower.

Step 4: Exploitation

The victim clicks a link (leading to a fake login page) or opens an attachment (executing malware). Credentials or access are captured silently.

Step 5: Post-Compromise

Stolen credentials are used to access email accounts, internal systems, or financial platforms. The attacker may also sell the credentials on dark web marketplaces.

9. Prevention Guidelines

For Individual Employees

- Always verify the sender's email address, not just the display name.
- Hover over links before clicking—check the actual destination URL.
- Never download unexpected attachments, especially executable files.
- Use multi-factor authentication (MFA) on all accounts.
- Report suspicious emails to your IT/security team immediately.
- When in doubt, contact the supposed sender through a separate, verified channel.
- Do not share passwords, OTPs, or sensitive data via email under any circumstances.

For Organizations

- Implement email authentication protocols: SPF, DKIM, and DMARC.
- Deploy email filtering and anti-phishing solutions at the gateway level.
- Conduct regular phishing simulation exercises to test employee readiness.
- Establish a clear incident reporting process with a dedicated reporting email/button.
- Provide ongoing security awareness training—not just annual compliance sessions.
- Enforce the principle of least privilege for all user accounts.
- Maintain and test an incident response plan specific to phishing compromises.

10. Do's and Don'ts for Employees

DO ✓	DON'T ✗
Verify sender identity before responding	Click links in unexpected emails
Hover over links to inspect URLs	Download attachments from unknown senders
Report suspicious emails immediately	Share passwords or OTPs via email
Use strong, unique passwords with MFA	Use the same password across services
Confirm requests via phone or in person	Trust emails solely based on display name
Keep software and antivirus updated	Ignore security training or warnings
Check for HTTPS and valid certificates	Forward phishing emails to colleagues

11. Incident Response Steps

If you suspect you've interacted with a phishing email, follow these steps immediately:

Step 1: Disconnect

If you downloaded a file or clicked a suspicious link, disconnect your device from the network (Wi-Fi and Ethernet) immediately.

Step 2: Do Not Delete the Email

Preserve the evidence. Your security team needs the original email for investigation.

Step 3: Report Immediately

Contact your IT/security team using the established reporting channel (phone, dedicated email, or reporting button in your email client).

Step 4: Change Your Passwords

If you entered credentials on a suspicious page, change your password for that account and any other accounts using the same password.

Step 5: Scan Your Device

Run a full antivirus/anti-malware scan on your device.

Step 6: Monitor Your Accounts

Watch for unauthorized access, unusual transactions, or unexpected password reset notifications in the following days.

Step 7: Cooperate with Investigation

Provide your security team with all details: what you clicked, what information you entered, and when it happened.

12. Conclusion & Recommendations

Phishing attacks continue to evolve in sophistication, but the fundamental defense remains the same: an informed and vigilant workforce. Technology alone cannot prevent phishing—human awareness is the critical last line of defense.

Key Recommendations

- Conduct phishing simulation exercises quarterly to maintain employee alertness.
- Update security awareness training to include the latest attack techniques and real-world examples.
- Implement and enforce email authentication (SPF, DKIM, DMARC) across all organizational domains.
- Establish a no-blame reporting culture where employees feel safe reporting suspicious emails without fear of punishment.
- Review and update incident response procedures at least annually.
- Consider deploying AI-powered email security solutions that can detect sophisticated phishing attempts.

This report is intended for internal security training and awareness purposes. All phishing samples analyzed are representative examples based on commonly observed attack patterns. No actual malicious content is included in this document.

Report generated: April 09, 2026 | Classification: Internal Use – Employee Training